NTNU

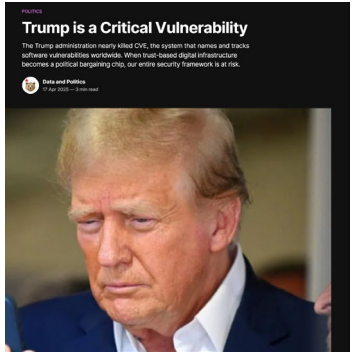
Norwegian University of Science and Technology

TDT4237 Software Security and Data Privacy – Summary

24.4.2026

Per Håkon Meland & Jingyue Li

President Trump's Cyber Strategy (March 2026)



https://www.dataandpolitics.net/trump-is-a-critical-vulnerability/

1. Shape Adversary Behavior
   - Deter and disrupt adversaries before they can inflict harm
2. Promote Common-Sense Regulation
   - Weaken rules on incident disclosure
3. Modernize and Secure Federal Government Networks
4. Secure Critical Infrastructure
   - US technologies only
5. Sustain Superiority in Critical and Emerging Technologies
   - Counter foreign AI systems used for censorship and surveillance
6. Build Cyber Talent and Capacity

https://www.whitehouse.gov/wp-content/uploads/2026/03/president-trumps-cyber-strategy-for-america.pdf

NTNU

Course summary - 1

Description	Students should be able to	To read
Security concepts and principles	• Understand basic security goals • Understand typical attacks • Apply high-level security guidelines	• Slides: Security principles

OWASP Top 10	• Understand various web application related attacks, vulnerabilities and countermeasures.
	• Be able to find out vulnerabilities in Python code snippets and know how to fix them
	• Explain various password related concepts and authentication methods
		• Slides: OWASP part 1, OWASP part 2,
		• OWASP Top 10 web page
		• OWASP web testing guide
		• Security engineering book
		  • 3.4 Passwords
		  • 3.5 CAPTCHAs
		  • 4.1 Information gathering
		  • 4.6 Session management
		  • 4.7 Injection attacks

Course summary - 2

Description	Students should be able to	To read
Cryptography introduction	• Explain various cryptography methods presented in the slides • Explain public & private key concepts, digital signature, certificates, and SSL handshake • Apply the cryptography methods correctly	• Slides: Crypto intro • Security engineering book (Chapter 5)
Authorization and Multi-Level Security Authentication and Single sign-on Control hijacking attacks	• Explain discretionary, mandatory, role-based, and attribute-based access control policy and their pros and cons • Explain Biba and Bell-LaPadula models • Explain SSO, SAML 2.0, OAuth 2.0, OpenID • Explain buffer overflow attack and mitigation	• Slides: Authorization and stuff • Security engineering book: Chapter 6 (Access control) and Chapter 9 (Multi-level security)

NTNU

Course summary - 3

Description	Students should be able to	To read
Threat modeling and STRIDE	• Explain what threat modeling is about • Explain the difference between attacker-centric and software-centric threat models • Apply various threat modeling methods, e.g., misuse case, attack tree, bow-tie and data flow diagrams • Explain and apply STRIDE	• Slides: Threat modeling and STRIDE (recorded) • The threat modeling manifesto: https://www.threatmodelingmanifesto.org/ (values and principles) • Security engineering book: Chapter 2: Who is the opponent, Chapter 27.3: Lessons from safety-critical systems

NTNU

Course summary - 4

Description	Students should be able to	To read

Risk management during development	• Explain the various steps typical of risk management (e.g., RMF)
	• Explain approaches on how to quantify risks
	• Apply RMF to analyze the security of a system
	• Explain the difference between good and bad security requirements
	• Define security requirements
	• Define a vulnerability score (CVSS)
		• Slides: Risk Management during development
		• Security engineering book:
		  • Chapter 8.6: The economics of security and dependability
		  • Chapter 27.2: Risk management
		  • Chapter 27.4: Prioritising protection goals
		• CVSS (Lecture slides and https://www.first.org/cvss/calculator/4.0)

NTNU

Course summary - 5

Description	Students should be able to	To read
Secure coding with LLMs	• Explain what AI assistants can do • Explain the benefits and risks of AI code assistants • Explain the reasons for the potential inclusion of vulnerable code patterns in LLM • Explain good developer practices to address vulnerable code generation	• Slides
Secure Development Activities and lifecycles	• Explain the prescriptive vs. descriptive secure development lifecycle models • Explain the seven touch points for software security • Explain the possible application scenarios of prescriptive and descriptive models	• Slides • https://www.opensamm.org/ • https://www.blackduck.com/services/security-program/bsimm-maturity-model.html • (Security engineering book: Chapter 27: Secure systems development)

Course summary – 6

Description	Students should be able to	To read

Microservice security
 	
Software supply chain security
	• Explain microservice architecture
	• Explain microservice security challenges
	• Explain microservice security countermeasures
	• Explain security patterns for microservices
	
	• Explain software supply threats
	• Explain countermeasures
	• Explain Transparency technologies (e.g. SBOM)
		• Slides: Microservice security
		• Slides: Software supply chain security
		• Recommended papers:
		  • SoK: Security of Microservice Applications: A Practitioners' Perspective on Challenges and Best Practices https://dl.acm.org/doi/pdf/10.1145/3538969.3538986
		  • SoK: Analysis of Software Supply Chain Security by Establishing Secure Design Properties https://docs.lib.purdue.edu/cgi/viewcontent.cgi?article=1177&context=ecepubs

NTNU

Course summary - 7

Description	Students should be able to	To read
Data Privacy and GDPR	• Explain data privacy and GDPR basics • Explain how to process personal data • Explain how to comply with data privacy principles • Explain data privacy activities and roles during product development • Understand a Data Protection Impact Assessment (DPIA)	• Slides from Knut: Privacy, Data Protection & GDPR (recorded) • (Security engineering: Chapter 26: Surveillance or privacy) • (https://gdpr-info.eu/)

NTNU

Course summary - 8

Description	Students should be able to	To read
Source code analysis	• Explain different static analysis approaches	• Slides from Tosin: Source code analysis
AI and cybersecurity	• Explain how AI and cybersecurity relate (AI for cybersecurity, malicious AI, cybersecurity for AI). • Explain prompt injection and Jailbreaking attacks	• Slides from Nektaria: AI and cybersecurity: with a focus on LLM security • (Security Engineering, Chapter 25.3 AI/ML)

Evaluation and grading

- Exercises and written exam
- Three exercises count for 100 points, in which you **must have at least 80 points in total, more than 80% each exercises 1 to 3,** to be eligible to take the exam.
- The distribution of the exercise grade is:
  - Exercise 1: 40 points (group exercise)
  - Exercise 2: 30 points (group exercise)
  - Exercise 3: 30 points (group exercise)

NTNU

EXAM 16.5.25
09:00-13:00

Structure of the exam

- Open-ended questions (about 3/4)
  - ~3 hours
- Close-ended questions (about 1/4)
  - ~45 minutes

(No big case study this year!)

Example open-ended question

- Explain the difference between Discretionary access control (DAC) and Mandatory access control (MAC). Give an example of each.

With DAC, the owner of a resource decides how it can be shared. The owner can choose to give read, write, or other access to other users. In contrast, MAC is a centralized access control model where access class is assigned to each subject and object.

DAC example: Linux file system, Google Docs, Sharepoint, Web applications
MAC example: Mac OS, Military systems, Trusted Computing Base

Another open-ended example

- Explain what a clickjacking attack is and how to defend against the clickjacking attack.

A clickjacking attack is when an attacker uses transparent layers to trick a user into clicking a button or link on the top-level page (which is transparent and malicious) when they intended to click on the button or link below the top-level page

To prevent clickjacking, you can implement any of the following defenses:

- Preventing other web pages from framing the site you want to defend (e.g., Defending with X-Frame-Options Response Headers)
- Employing defensive code in the UI to ensure that the current frame is the most top-level window

Yet another open-ended…

- Explain the difference between privacy and confidentiality

Privacy means control of your own secrets, whereas *Confidentiality* is an obligation to protect someone else's secrets. **For instance**, your medical privacy is protected by your doctors' obligation of confidentiality.

Examples are recommended!

And another…

http://www.exampleTDT4237.com/reset-password?token=eyJhbGciOiJIUzI1NiIsInR5crheyKiwIwk.eyJzdWIiOiIxMjM0NTY3ODkwIiwi

- 1) How can someone exploit this?
- 2) What can you do to protect such tokens? Name at least 2 ways.

Tokens in URLs can be easily exposed through browser history, server logs, network sniffing and other means. In this case, someone can obtain the token and use that to change the password of the user.

1. Use HTTPS: HTTPS encrypts the communication between the client and server, preventing attackers from intercepting and stealing the token.
2. Generate unique tokens: Generate a unique token for each user and each session, and ensure that each token can only be used once. This way, even if an attacker intercepts a token, they will not be able to reuse it in a subsequent request.
3. Limit token lifespan: Set an expiration time for each token, so that even if an attacker intercepts it, they will only be able to use it for a limited time period.

Example close-ended questions

Mentimeter

Q&A

- Do we have to submit a drawing/sketch on the exam?
  - No
- Am I allowed to use a dictionary?
  - You are allowed to use a simple bilingual dictionary if the examination is held in a language other than your native tongue. **You do not have to apply for this.**
  - https://i.ntnu.no/wiki/-/wiki/English/Permitted+examination+aids
- Do we have to code during the exam?
  - Find vulnerabilities and fix
  - Note that copy-paste does not work well in Safeexambrowser (at least from what I remember).

Q&A

- How to prepare for questions related to code?

One of my master's students (williarh@stud.ntnu.no) created software to help TDT4237 students prepare for code-related exams as part of his thesis.

The link is http://89.167.30.18/

Note: The app is deployed outside of NTNU. You shall NOT use your real or NTNU email and password to register and log in there. Please use a faked email and password for registration and logging in.

Please leave feedback (a feature of the current version of the tool) after using it so we can improve it.

Q&A

- Would it be possible to get a solution for the 2022 exam?
  - We only have a censor guide, which is not the same as a solutions. You should rather look for solutions in the curriculum (then you will learn more as well).
  - Inspera does not allow for censor guide export
- How long did old exams last for?
  - 4 hours
- Can Per Håkon and Jingyue be bribed?
  - No use, won’t be doing the grading

Q&A

- Will you say the code questions in the exam will resemble exercise 1/2 in difficulty level?
  - There are usually different levels of coding questions on the exam. None that are super hard since you have limited time and no help.
- Will I get a negative score for incorrect answers?
  - No, so better to guess than leave blank
- What happens if I fail the exam?
  - Welcome back after the summer

Tips

- Use the slides as the table of content to the reading material
- The exam will focus on applying the theories you have learned from lectures, reading the book chapters (++) and performing exercises
- The case studies and questions in previous years' exams can be used for practice
- Not all questions from previous years are relevant to this year, e.g., we did not cover pentesting and social engineering this year
- There is a discussion channel in Blackboard for Q&A exam related questions

Edu game tip

https://www.hacktivate.app/

"That's all Folks!"